

The seal of the University of Coimbra is a circular emblem. It features a central figure, likely a saint or scholar, seated and holding a book. The figure is surrounded by a decorative border containing the text 'CONIMBRIGENSIS' and 'SITATIS'. The seal is rendered in a light blue color.

Security Auditing

Lesson#3

Introduction to ISO27001 Family

School Year 2024/2025

Master in Informatics Engineering (MEI)
Master in Informatics Security (MSI)

Informatics Engineering Department

University of Coimbra



Learning Objective

- Understand the structure of ISO27000 family
- Discuss the principles of an Information Security Management System



Agenda

1. Introduction to ISO 27000 Series
2. ISO 27001: Information Security Management System (ISMS)



Agenda

1. Introduction to ISO 27000 Series

1.1 Overview of the ISO 27000 Family

1.2 Importance of Information Security Standards

1.3 Key Objectives of the ISO 27000 Series



1.1 Overview of the ISO 27000 Family

- What is ISO 27000?
 - A family of standards that provide a framework for managing information security risks systematically.
 - Developed by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC).



1.1 Overview of the ISO 27000 Family

- Structure of the ISO 27000 Family

- ISO 27001 – Defines the principles of Information Security Management (the only certifiable standard).
- ISO 27002 – Guidelines for implementing security controls.
- ISO 27003 – Information Security Management System (ISMS)
- ISO 27005 – Information security risk management framework.
- ISO 27007 – Defines the execution of Security Audits
- ISO 27701 – Privacy Information Management System (PIMS) for GDPR compliance.
- ISO 27017 & 27018 – Cloud security and protection of Personally Identifiable Information (PII).
- ISO 27035 – Security incident management.



1.1 Overview of the ISO 27000 Family

- Evolution of the ISO 27000 Standards:
 - Originally based on BS 7799 (British Standard for Information Security).
 - Regular updates to keep up with emerging security threats.

Latest version: ISO27001:2022



1.1 Overview of the ISO 27000 Family

- Discussion
 - Have any of you ever worked under ISO 27000?
 - **If yes**, what challenges did you feel?
 - **If not**, what security challenges did you face?



1.2 Importance of Information Security Standards

- Why do organizations need information security standards?
 - How would you convince a CFO to spend money on ISO27001?
 - What are the biggest security risks their organizations face today?



1.2 Importance of Information Security Standards

- Why do organizations need information security standards?
 - **Protection** of sensitive data.
 - Regulatory and legal **compliance** (e.g., GDPR, HIPAA, SOC 2).
 - **Trust** and credibility with stakeholders.



1.2 Importance of Information Security Standards

- Key Benefits of Implementing ISO 27000 Standards:
 - **Structured approach** to managing security risks.
 - Reduces financial and reputational losses due to **security incidents**.
 - Improves **business continuity** and resilience.
 - Increases customer and partner **confidence**.



1.2 Importance of Information Security Standards

- Consequences of Not Following Security Standards:
 - Data breaches and cyberattacks (examples: Equifax, SolarWinds).
 - Legal and financial penalties.
 - Reputational damage.



1.3 Key Objectives of the ISO 27000 Series

- Primary Goals of the ISO 27000 Standards:
 - Establish, implement, maintain, and continually improve an Information Security Management System (ISMS).
 - Protect confidentiality, integrity, and availability (CIA Triad) of information.
 - Ensure a risk-based approach to managing security threats.



1.3 Key Objectives of the ISO 27000 Series

- ISO 27000 as a Business Enabler:
 - Aligns security objectives with business goals.
 - Provides a competitive advantage for organizations seeking global clients.



1.3 Key Objectives of the ISO 27000 Series

- How ISO 27000 Standards Fit into Cybersecurity Strategy:
 - Complements other security frameworks (NIST, CIS Controls).
 - Helps in compliance with data protection laws (GDPR, CCPA).



Agenda

2. ISO 27001: Information Security Management System (ISMS)

2.1 Scope and Purpose of ISO 27001

2.2 Core Components of ISMS

2.3 Context of the Organization

2.4 Risk Assessment and Management

2.5 Certification Process



2.1 Scope and Purpose of ISO 27001

- What is ISO 27001?
 - A globally recognized standard for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS).
 - The only certifiable standard in the ISO 27000 family.



2.1 Scope and Purpose of ISO 27001

- Purpose of ISO 27001:
 - Ensures a systematic approach to protecting information security.
 - Identifies and mitigates security risks.
 - Provides a framework for legal and regulatory compliance.



2.1 Scope and Purpose of ISO 27001

- Who Needs ISO 27001?
 - Any company interested in protecting its information
 - Companies handling sensitive data (finance, healthcare, IT, government).
 - Organizations aiming for global business and client trust.
 - Any other?



2.2 Core Components of ISMS

- What is an ISMS?

“An ISMS takes a systematic approach to securing the CIA (confidentiality, integrity, and availability) of corporate information assets. An ISO 27001 ISMS consists of organizational, people, physical, and technological controls, selected on the basis of regular risk assessments.”

- A structured system to manage and protect sensitive information.
- Based on a Plan-Do-Check-Act (PDCA) cycle.



2.2 Core Components of ISMS

- Core Components of ISMS:

Important for the Practical Assignment!

- **Leadership and Commitment:** making sure the organization supports it
- **Policies and Procedures:** Documented rules for information security.
- **Asset Management:** Identifying and classifying information assets.
- **Access Control:** Managing user permissions and authentication.
- **Risk Management:** Identifying, assessing, and mitigating risks.
- **Incident Response:** Preparing for and handling security breaches.
- **Continuous Improvement:** Monitoring and updating security measures.



2.2 Core Components of ISMS

- Core Components of ISMS:

- **Leadership and Commitment:** making sure the organization supports it

- Senior Management Involvement: Leadership must actively support and drive the ISMS.
 - Defining Roles & Responsibilities: assigning security-related tasks within the organization.
 - Establishing an Information Security Policy: High-level document stating the organization's commitment to security.

Why It Matters:

- Without top-level commitment, ISMS implementation will lack funding, authority, and proper governance.



2.2 Core Components of ISMS

- Core Components of ISMS:

- **Policies and Procedures:** Documented rules for information security.

- Information Security Policy: The overarching security principles and objectives of the organization.
 - Operational Procedures: Specific guidelines on how security policies are implemented.
 - Acceptable Use Policy (AUP): Defines how employees and stakeholders can use IT resources.
 - Data Classification Policy: Categorizing data based on sensitivity (e.g., Public, Confidential, Restricted).
 - Documented Security Controls: How security measures align with Annex A of ISO 27001.

Why It Matters:

- Clear policies and procedures ensure consistency in security practices across the organization.



2.2 Core Components of ISMS

- Core Components of ISMS:

- **Asset Management:** Identifying and classifying information assets.

- Identifying Information Assets: Hardware, software, databases, documents, intellectual property.
 - Ownership Assignment: Each asset must have an accountable owner.
 - Classification of Assets: Defining the value and security level of each asset.
 - Asset Handling Procedures: Guidelines on storage, transfer, and disposal of assets.

Why It Matters:

- Without asset management, an organization cannot effectively protect its most critical data.



2.2 Core Components of ISMS

- Core Components of ISMS:

- **Access Control:** Managing user permissions and authentication.

- Principle of Least Privilege (PoLP): Employees should have the minimum access necessary to perform their job.
 - Role-Based Access Control (RBAC): Access permissions based on job functions.
 - User Authentication Mechanisms: Password policies, multi-factor authentication (MFA), biometric access.
 - Regular Access Reviews: Periodically reviewing and revoking unnecessary access rights.

Why It Matters:

- Access control reduces the risk of unauthorized data breaches.



2.2 Core Components of ISMS

- Core Components of ISMS:

- **Risk Management:** Identifying, assessing, and mitigating risks.

- Risk Identification: Recognizing threats to information security.
 - Risk Analysis & Evaluation: Determining the likelihood and impact of security incidents.
 - Risk Treatment: Selecting appropriate measures to mitigate risks (Avoid, Transfer, Mitigate, Accept).
 - Risk Register: A document tracking identified risks and their treatment strategies.

Why It Matters:

- A strong risk management process prevents security incidents and ensures compliance with regulatory requirements.



2.2 Core Components of ISMS

- Core Components of ISMS:

- **Incident Response:** Preparing for and handling security breaches.

- Incident Response Plan (IRP): Steps to detect, respond to, and recover from security incidents.
 - Security Incident Logging & Reporting: Ensuring all security events are recorded for forensic analysis.
 - Disaster Recovery Plan (DRP): Procedures for restoring IT services after a cyberattack or natural disaster.
 - Business Continuity Plan (BCP): Ensuring critical operations continue during a security incident.

Why It Matters:

- A well-prepared organization can quickly respond to security incidents and minimize damage.



2.2 Core Components of ISMS

- Core Components of ISMS:

- **Continuous Improvement:** Monitoring and updating security measures.

- Internal Audits: Regular checks to assess compliance with ISO 27001 and identify weaknesses.
 - Performance Metrics & KPIs: Measuring security effectiveness (e.g., number of incidents, response times).
 - Third-Party Audits & Compliance Checks: Verifying adherence to external regulations (GDPR, SOC 2).
 - Continuous Improvement (PDCA Cycle)

Why It Matters:

- Security threats evolve constantly, requiring organizations to adapt and improve their ISMS.



2.3 Context of the Organization

- Understanding Business Context in ISMS Implementation:
 - External factors: Legal requirements, regulatory compliance, market trends.
 - Internal factors: Business strategy, organizational structure, existing security measures.



2.3 Context of the Organization

- Stakeholder Analysis:

- Identifying internal and external stakeholders (employees, customers, regulators).
- Understanding their expectations regarding information security.



2.3 Context of the Organization

- Defining Scope of the ISMS:
 - Determining which assets, processes, and business functions are covered under ISMS.
 - Setting boundaries based on business requirements and risk assessments.
 - What challenges do organizations face when defining ISMS scope?



2.4 Risk Assessment and Management

- Risk-Based Approach in ISO 27001:
 - Identifying threats and vulnerabilities.
 - Assessing the likelihood and impact of security incidents.
 - Implementing controls to mitigate risks.



2.4 Risk Assessment and Management

- Risk Assessment Process:
 - **Identify Information Assets:** What data needs protection?
 - **Identify Threats & Vulnerabilities:** Cyberattacks, insider threats, weak controls.
 - **Assess Risks:** Probability vs. Impact matrix.
 - **Define Risk Treatment Options:** Avoid, transfer, mitigate, or accept risks.



2.4 Risk Assessment and Management

- Common Risk Treatment Strategies:
 - **Accept**: you accept the risk. If it happens, it happens.
 - **Transfer**: take an insurance. The cost of the impact is transferred to the insurance carrier.
 - **Mitigate**: trying to reduce impact, probability, or both.
 - **Enhance**: in positive risks (opportunities), expanding the probability or impact, or both.

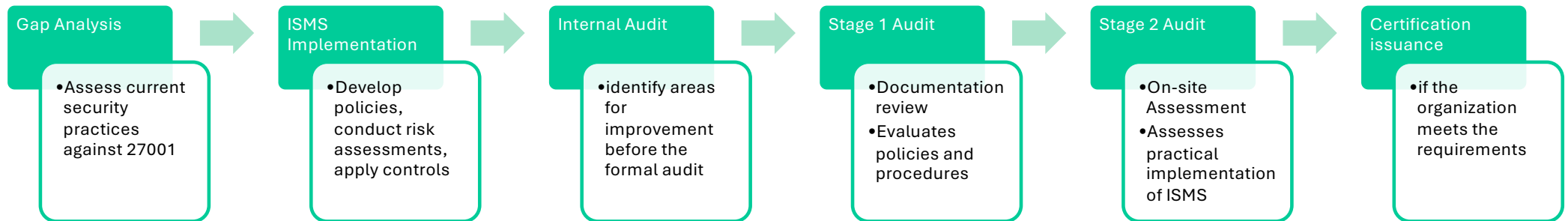


2.5 Certification Process

- Why Get Certified?
 - Competitive advantage and customer trust.
 - Compliance with regulatory and industry standards.
 - Improved risk management and security posture.

2.5 Certification Process

- Steps to ISO 27001 Certification:





2.5 Certification Process

- Maintaining Certification:
 - Regular internal audits.
 - Continuous improvement.
 - Periodic surveillance audits by the certification body.



Summary

- ISO27000 is a family of standards for Management of Information Security
- ISO27001 as a structured approach
- ISO27001 is fully connected with business objectives